

TERAPIA**SEGURANÇA**

Modelo de Ameaças STRIDE e Casos de Abuso

Segurança cibernética, segurança de IA e uso indevido

Projeto	TerapIA: Plataforma Móvel para apoio mental com Inteligência Artificial
Coordenador	Carlos Gracioli Neto
Instituição	Instituto Federal de Educação, Ciência e Tecnologia de Mato Grosso - IFMT - Campus Várzea Grande
Período	01/09/2025 a 31/08/2026
Referência	Projeto de Pesquisa 138/2025 - PROPES/IFMT

Repositório técnico e documentação: <https://github.com/devfullstackNeto/terapia>

Entrega final - 2026

1. Ativos críticos

- Identidade e credenciais.
- Diário e check-ins.
- Mensagens e eventos de segurança.
- Agenda.
- Base de conhecimento e políticas.
- Configuração de modelo/provedor.
- Registros de auditoria.
- Diretório de ajuda.

2. STRIDE

Categoria	Cenário	Controle
Spoofing	Conta administrativa comprometida	MFA previsto, tokens curtos e revogação
Tampering	Alteração silenciosa da base	Versionamento, hash e auditoria
Repudiation	Administrador nega mudança de política	Evento auditável
Information Disclosure	Exposição de diário	RBAC, criptografia e ausência de logs de conteúdo
Denial of Service	Abuso de login/chat	Limite de taxa, fila e contingência
Elevation of Privilege	Usuário acessa API administrativa	RBAC e negação por padrão

3. Casos de abuso específicos de IA

ID	Ataque/uso indevido	Comportamento seguro
AB-01	Injeção de instruções para remover regras	Políticas mantêm precedência
AB-02	Pedido repetido de diagnóstico	Recusa consistente
AB-03	Pedido de dose/medicamento	Recusa + profissional humano
AB-04	Forçar relação exclusiva	Resposta antidependência
AB-05	Inventar contato de emergência	Somente contatos configurados
AB-06	Extrair instruções internas/base	Não revelar controles sensíveis
AB-07	Usar texto de outro usuário	Isolamento por usuário
AB-08	Envenenamento da base	Fluxo de revisão/publicação + auditoria

4. Catálogo de testes de segurança

ID	Teste
SEC-001	IDOR em diário e check-ins
SEC-002	RBAC administrativo
SEC-003	Revogação de sessão/token
SEC-004	Limite de taxa em chat/login
SEC-005	Mass assignment
SEC-006	XSS armazenado em base/diário
SEC-007	Corpus de injeção de instruções
SEC-008	Varredura de segredos
SEC-009	Varredura de dependências
SEC-010	Controle de acesso de backup/restauração